



## INFORMATION SECURITY GOVERNANCE AND RISK MANAGEMENT

MECR1023 – 52

2025/2026

### LECTURER

ASSOCIATE PROF DR NORAFIDA ITHNIN

### FINAL EXAMINATION SEMESTER 1

| NAME                            | MATRIC NO. | I/C No.      |
|---------------------------------|------------|--------------|
| KEERTENNAH DEVI A/P PONNAMBALAM | MEC254026  | 001201080866 |

## **PART A: Risk Analysis & Strategic Planning**

### **1. Risk Prioritization and Justification**

#### **CISO REPORT: HIGH IMPACT 12-MONTH SECURITY PROGRAM**

TechSolutions Cyber Security Program

To : Chief Executive Officer TechSolutions

From : Cyber Security Program Manager

Data : 14 February 2026

Subject: Executive Report Risk Prioritization and Strategic Security Program Proposal

#### **Summary**

TechSolutions operates at a critical point because we have a technologically mature organization with clients who trust us with their systems and data. However, we have an underdeveloped information security culture. Recent risk assessment findings have identified that the biggest risks to TechSolutions are behavioral. Three high-frequency human risk factors have been identified through formal risk assessment based on the report given. Of these identified risks, phishing has been identified as an extreme risk (Score 25) requiring immediate executive level attention. In contrast, weak password sharing (Score 16) and shadow IT (Score 16) have been identified as high risks requiring dedicated mitigation strategies to be included in the current fiscal year.

#### **Urgency Statement**

In the last 90 days, a simulated phishing campaign has achieved a 34% click-through rate among our privileged users. Concurrently, the Operations and Development teams who have administrative access to our systems continue to share credentials through unencrypted instant messaging and document sharing. This is not a technological problem, but it is a cultural problem. If left unchecked, this situation will inevitably lead to a catastrophic breach within 12–18 months.

#### **Prioritized Risk Matrix**

| Risk                  | Likelihood | Impact           | Score       | Priority       | Action Required                              |
|-----------------------|------------|------------------|-------------|----------------|----------------------------------------------|
| Phishing              | 5 (High)   | 5 (Catastrophic) | 25 – Red    | P1 (Extreme)   | Immediate mitigation and executive attention |
| Weak Password Sharing | 4 (High)   | 4 (Major)        | 16 – Orange | P2 (Very High) | Dedicated mitigation plan and timeline       |
| Shadow IT             | 4 (High)   | 4 (Major)        | 16 – Orange | P3 (High)      | Routine monitoring and future planning       |

#### **Justification for Risk Prioritization**

##### **Phishing: Extreme risk (Score 25/25)**

Phishing is not just one of many threats, but it is the first point of attack for 91% of all types of cyber incidents for organizations of our type. TechSolutions is particularly vulnerable to phishing

because of the following reasons. Our workforce is exposed to sophisticated and targeted spear phishing operations every day.

Our company, being an IT services provider, has administrative credentials of high value to threat actors who wish to use our clients' networks. Our email gateway controls, though technically adequate, become ineffective when users willingly provide credentials or execute attachments. A single successful credential theft event could result in ransomware distribution across our development environments, halting service delivery business compromise leading to wire transfer fraud. The average cost of a breach is in the millions. A Business Email Compromise (BEC) incident could result in fraudulent payments or catastrophic incident response fees. A phishing-induced breach is not like a software bug, where a security flaw is a private failure to live up to our duty of care. Our clients trust us with their security. If we cannot protect ourselves, we cannot credibly claim to protect them. Phishing is our highest priority.

Despite having implemented MFA on 89% of privileged accounts as a requirement, we continue to suffer a click-through rate of 34% on phishing simulations that nearly seven times the industry average of 5%.

#### Weak Password Sharing: Very High Risk (Score 16/20)

In our highly privileged Operations and Development teams, shared credentials have made efficiency a norm over security. This has resulted in a single point of failure where an attacker can operate under a shared admin account with no audit trail. We cannot distinguish between a malicious actor and a legitimate engineer. This causes delays in incident response and allows attackers to establish backdoors without detection.

#### Shadow IT: Very High Risk (Score 16/20)

Our developers are introducing unvetted software, which bypasses our patch management and introduces known vulnerable entry points. The use of unlicensed software puts us at great risk for significant fines, as well as damaging our relationships with our software vendors.

#### Conclusion

TechSolutions has a decision to make. We can continue to view security awareness as an annual compliance exercise for our unengaged employees who quickly fall back into their convenient behaviors. We can recognize that our human attack surface is our biggest risk exposure and invest accordingly.

#### Recommendation

I formally recommend that the High-Impact 12-Month Security Program be immediately approved and initiated. This program will transition from a purely technology-based defense to a three-tiered defense of Technology, Process, and Culture or SETA and focus on mandatory MFA deployment. This is the only way to mitigate these risks and protect the company's reputation and revenue streams.

## 2. Core Program Proposal

| Initiative Name                                                 | SETA Classification | Description and Specific Mitigation Strategy                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-----------------------------------------------------------------|---------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1. Just-in-Time (JIT)<br>Access privileged<br>access management | Training            | <p><u>Description:</u></p> <p>This approach effectively removes the technical possibility of password sharing by replacing static administrative credentials with a model that provides privileged access on an on-demand basis, for a specific duration, and to the individual requesting access.</p> <p>In this regard, if an engineer needs to have administrative access to perform a specific task, they can request this through an automated portal. The request is pre-configured by role, time of day, and system sensitivity. The access is granted for a specific session, such as 60 to 120 minutes, and then automatically terminates at the end of the session. All actions performed within the session are logged into the specific user account.</p> <p><u>Mitigation of Phishing:</u></p> <p>For a stolen credential to be useful to an attacker, it must be valid at the time it is attempted to be used. If an attacker phishes a temporary credential, it has expired by the time it is attempted to be reused. If an attacker phishes a standard user credential, it does not provide privilege access. Therefore, the threat to our engineers from credential theft attacks diminishes significantly. This does not eliminate phishing attacks, but it simply makes phishing attacks on privilege credentials less effective.</p> <p><u>Mitigation of Password Sharing:</u></p> <p>One cannot share a password which does not exist as a static, reusable secret. The shared administrative account is either decommissioned or is configured in a manner where the password remains unknown to any individual. The shared Excel document, Slack channel, and WhatsApp message become irrelevant as there is no password to disseminate. The professionals who exchanged credentials due to constraints in workflow now operate under a sanctioned mechanism to access the credentials. The behavioral rationale to exchange credentials is eliminated.</p> |

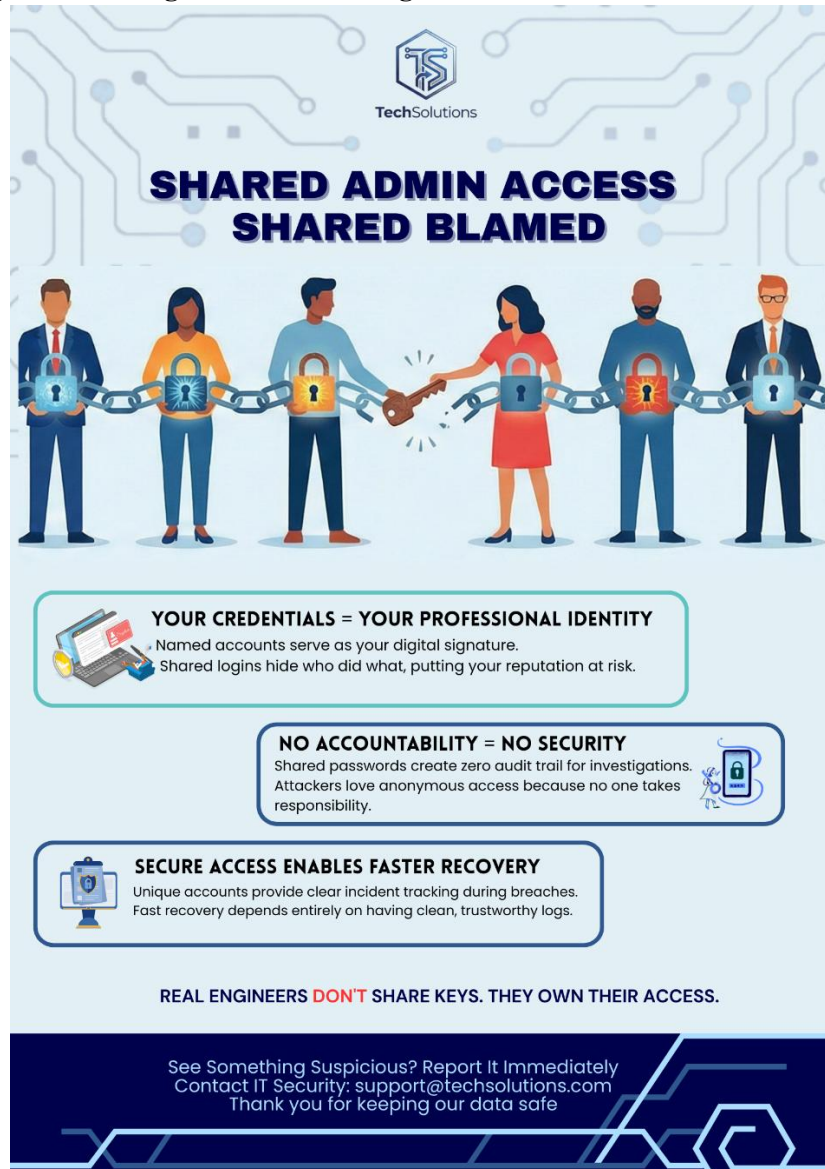
|                                              |           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|----------------------------------------------|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                                              |           | <p><u>Implementation Timeline</u></p> <p>Month 1: Vendor selection and procurement activities.</p> <p>Month 2: Designing the integration with the existing identity provider (IdP).</p> <p>Month 3: Pilot project with a single operations team.</p> <p>Month 4: Complete cutover on all privileged access in both operations and development.</p> <p>Months 5-12: Ongoing adoption monitoring and refinement of the workflows.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| 2. Phishing simulation and coaching platform | Education | <p><u>Description:</u></p> <p>Monthly simulated phishing tests are conducted with all staff members. An important element of the program is the coaching that occurs as soon as the individual engages with the simulated phishing email.</p> <p>The individual does not receive any information that the attempt was unsuccessful. Instead, the individual is taken through an interactive process for 60 seconds that shows the email clicked on, the visual cues of the deception technique used, what the email should really look like if it were authentic, the proper verification processes like hovering over the links, checking the sender email address, and one action that the individual can apply immediately.</p> <p>There is no reporting of any identifying information to the managers. The only focus is skill-building in real-time.</p> <p><u>Mitigation of Phishing:</u></p> <p>This method promotes the creation of a detection habit. Simulations are repeated to assist users in identifying patterns. They can recognize urgency cues, domain spoofing, and attachment risks. The aim is to lower click-through rates from 34% to below 5% within 12 months.</p> <p><u>Mitigation of Password Sharing:</u></p> <p>The program also improves vigilance by working on password reuse and sharing behaviors through simultaneous coaching activities that are carried out once simulations involve credential harvesting. Users can understand how shared credentials increase the damage of phishing.</p> |

|                               |           |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
|-------------------------------|-----------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|                               |           | <p><u>Implementation Timeline</u></p> <p>Month 1: Procurement of the platform and integration activities.</p> <p>Month 2: Baseline measurement campaign is carried out without the use of coaching.</p> <p>Months 3-12: Monthly campaigns that incorporate the use of embedded coaching.</p> <p>Quarterly: Department-level trend reporting is provided to the leadership.</p> <p><u>Success Criteria</u></p> <ul style="list-style-type: none"> <li>- A 12-month reduction in the privileged user click rate from 34% to below 12%.</li> <li>- All employees are exposed to at least six coaching sessions.</li> <li>- Improvement in the phishing identification assessment scores.</li> </ul>                                                                                                                                                                                                                                                                                                                                                             |
| 3. Security champions program | Awareness | <p><u>Description:</u></p> <p>Identify and train 1-2 trusted technical leads within each of the Operations and Development teams, resulting in 8 to 12 overall champions. Advanced threat briefings will be provided monthly, privileged access will be granted to the security team, and champions will be formally recognized. They will be peer consultants, not enforcers.</p> <p><u>Mitigation of Phishing:</u></p> <p>The team champions promote awareness among team members through the dissemination of phish examples identified as "Phish of the Week" during stand-up meetings. This brings to the fore realistic threat scenarios within the context of the codebase.</p> <p><u>Mitigation of Password Sharing:</u></p> <p>The team champions promote good citizenship by using password managers and seeking JIT access. They correct team members who are promoting password sharing "just this once."</p> <p><u>Implementation Timeline</u></p> <p>Month 1 - Distribution of nomination requests to operations or development Directors.</p> |

|  |  |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|--|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|  |  | <p>Month 2 - Selection and public announcement of champions.</p> <p>Month 3 - Initial briefing and formal kickoff.</p> <p>Months 4-12 - Ongoing monthly engagement and feedback collection.</p> <p>Quarter 4 - Conduct program evaluation and initiate next month planning.</p> <p><u>Success Criteria</u></p> <ul style="list-style-type: none"> <li>- All Operations or Development teams (100%) have at least one active security champion.</li> <li>- Monthly peer engagement activities are documented by champions.</li> <li>- Qualitative feedback indicates improvement in security communication between teams.</li> </ul> |
|--|--|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

## PART B: Training & Communication Components (SETA Components)

### 1. Poster Design: Addressing Password Sharing



Poster design for security awareness for Ops and Dev team

### 2. Video Plan: Addressing Phishing



Video link: <https://youtu.be/X35qZ1KYAMM>



## **PART C: Measurement & Sustainability**

### **1. Success Metrics and Data Collection**

| <b>KPI</b>                     | <b>Type</b>           | <b>Target</b>                                                      | <b>Baseline (Current)</b>                                  | <b>Data Collection Method</b>                                                                                                                                                                                     | <b>Frequency</b>                                    |
|--------------------------------|-----------------------|--------------------------------------------------------------------|------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------|
| Privileged Access Request Rate | Behavioral Change     | More than 95% of privileged sessions use JIT or elevation workflow | 12% password manager adoption with no current JIT workflow | PAM logs: Extract percentage of privileged sessions initiated through approved elevation workflow vs. shared static credential usage. Requires deployment of PAM solution with session recording and attribution. | Weekly dashboard and monthly executive report       |
| Mean Time to Report Phishing   | Control Effectiveness | Less than 15 minutes from receipt to report                        | 4.2 hours current manual reporting                         | Phishing simulation platform plus email reporting integration: Timestamp from email delivery to user-initiated report button click. Automated capture and no self-reporting bias.                                 | Pre-campaign measurement and monthly trend analysis |

#### **Justification for KPI Selection:**

Privileged Access Request Rate is a direct measure of whether Operations or Development teams have adopted an approved methodology for access rather than insecure methods of password sharing. It is not a proxy measure, unlike password manager adoption, as it measures actual changes in work behaviors, not just a choice to adopt a new tool. It is a concrete measure that converts the abstract concept of having “bought the tool” to that of having “altered work practices.”

Mean Time to Report Phishing is a measure of control effectiveness that takes into consideration both detection capability and psychological safety. A low reporting time indicates that not only are users able to recognize threats, but they also feel empowered to report them without fear of reprisal. A decrease in Mean Time to Respond (MTTR) indicates a reduction in dwell time and an increase in SOC response capability.

### **2. Program Sustainability**

#### **Mechanism 1: Red vs. Blue Team "Purple Exercise" with Board Observation**

##### **Description**

The project evolves from simulated phishing attacks to comprehensive adversarial simulations. An external red team is engaged to deliver a coordinated attack scenario involving phishing, attempts

at privileged credential compromise, and simulated data exfiltration. Meanwhile, the internal blue team, comprising security staff and trained Security Champions defend against the attacks in real-time. The simulation concludes with a joint “purple team” analysis workshop which aims to identify detection gaps and improve response mechanisms.

Reason why Year 1 no repeated

Year 1 focuses on foundational awareness and individual behavioral change. Year 2 introduces competitive team-based validation of collective capability. Observation of the simulation raises security from an IT issue to an enterprise-wide risk management issue, turning passive training into an active, measurable demonstration of defense.

Maturity shift:

Individual compliance → Organizational resilience

### Mechanism 2: Gamified Security Bounty Program

Description

Suggest the development of an internal leaderboard under the title "Security Contributor." The leaderboard would reward employees who have contributed to the security of the company through the following methods:

1. Reporting campaigns that were not previously known to be carried out by the company.
2. Reporting configuration issues within the access control lists.
3. Providing improvements to the security documentation and playbooks.
4. Completing advanced security training modules.

The reward would be public recognition that is not financially motivated and relevant to the employee's career, such as the addition of a "CISO Commendation" to the employee's file access to advanced training and an invitation to quarterly security strategy meetings with the company's executives. A physical reward would be given to the employee in the form of a customized T-shirt or crest and would be presented at all-hands meetings.

Reason why Year 1 no repeated

Year 1 focuses on mandatory participation and minimum competency. Year 2 focuses on voluntary excellence and intrinsic motivation. The mechanism uses the concept of professional pride rather than enforcement by compliance. It frames security proficiency as a career-enhancing skill rather than an administrative requirement.

Maturity Shift

Required compliance → Valued contribution

Submitted for approval:

A handwritten signature in black ink, appearing to read 'Keefennah', is written over a light gray rectangular background.

.....  
Cyber Security Program Manager  
TechSolutions  
14 February 2026